

Zakon i kibernetičkoj sigurnosti

(1) Ovaj Zakon primjenjuje se na operatore ključnih usluga, neovisno o tome jesu li u pitanju javni ili privatni subjekti, neovisno o državi njihova sjedišta, njihovoj veličini, ustroju i vlasništvu.

(2) Davatelji digitalnih usluga podliježu nadležnostima i ovlastima propisanim ovim Zakonom ako na teritoriju Republike Hrvatske imaju sjedište ili svog predstavnika te pod uvjetom da takav davatelj ne predstavlja mikro ili mali subjekt maloga gospodarstva kako su oni definirani zakonom kojim se uređuju osnove za primjenu poticajnih mjera gospodarske politike usmjerenih razvoju, restrukturiranju i tržišnom prilagođavanju maloga gospodarstva.

Pojedini javni ili privatni subjekt (u daljnjem tekstu: subjekt) odredit će se operatorom ključnih usluga ako:

- a) subjekt pruža neku od ključnih usluga s Popisa iz Priloga I. ovog Zakona (u daljnjem tekstu: ključna usluga)
- b) pružanje ključne usluge kod tog subjekta ovisi o mrežnim i informacijskim sustavima i
- c) incident bi imao znatan negativan učinak na pružanje ključne usluge.

Operatori ključnih usluga dužni su poduzimati tehničke i organizacijske mjere za upravljanje rizicima koje moraju obuhvatiti mjere za:

- utvrđivanje rizika od incidenata
- sprječavanje, otkrivanje i rješavanje incidenata i
- ublažavanje učinka incidenata na najmanju moguću mjeru

Davatelji digitalnih usluga dužni su prilikom poduzimanja tehničkih i organizacijskih mjera za upravljanje rizicima voditi računa osobito o:

- sigurnosti sustava i objekata
- rješavanju incidenata
- upravljanju kontinuitetom poslovanja
- praćenju, reviziji i testiranju
- sukladnosti s međunarodnim standardima

POPIS KLJUČNIH USLUGA S KRITERIJIMA I PRAGOVIMA ZA UTVRĐIVANJE VAŽNOSTI NEGATIVNOG UČINKA INCIDENTA

1. Energetika
2. Prijevoz
3. Bankarstvo
4. Infrastrukture financijskog tržišta

5. Zdravstveni sektor
6. Opskrba vodom za piće i njezina distribucija
7. Digitalna infrastruktura
8. Poslovne usluge za državna tijela

POPIS DIGITALNIH USLUGA

1. Internetsko tržište
2. Internetska tražilica
3. Usluge računalstva u oblaku

ZAKON O INFORMACIJSKOJ SIGURNOSTI

(1) Ovim se Zakonom utvrđuje pojam informacijske sigurnosti, mjere i standardi informacijske sigurnosti, područja informacijske sigurnosti, te nadležna tijela za donošenje, provođenje i nadzor mjera i standarda informacijske sigurnosti.

(2) Ovaj se Zakon primjenjuje na državna tijela, tijela jedinica lokalne i područne (regionalne) samouprave te na pravne osobe s javnim ovlastima, koje u svom djelokrugu koriste klasificirane i neklasificirane podatke.

(3) Ovaj se Zakon primjenjuje i na pravne i fizičke osobe koje ostvaruju pristup ili postupaju s klasificiranim i neklasificiranim podacima

Područja informacijske sigurnosti za koja se propisuju mjere i standardi informacijske sigurnosti su:

- sigurnosna provjera,
- fizička sigurnost,
- sigurnost podatka,
- sigurnost informacijskog sustava,
- sigurnost poslovne suradnje

Ured Vijeća za nacionalnu sigurnost

Članak 14.

Ured Vijeća za nacionalnu sigurnost je središnje državno tijelo za informacijsku sigurnost koje koordinira i usklađuje donošenje i primjenu mjera i standarda informacijske sigurnosti u Republici Hrvatskoj i u razmjeni klasificiranih i neklasificiranih podataka između Republike Hrvatske i stranih zemalja i organizacija.

Članak 15.

(1) Ured Vijeća za nacionalnu sigurnost donosi Pravilnik o standardima sigurnosne provjere, Pravilnik o standardima fizičke sigurnosti, Pravilnik o standardima sigurnosti podataka, Pravilnik o standardima organizacije i upravljanja područjem sigurnosti informacijskih sustava te Pravilnik o standardima sigurnosti poslovne suradnje

(2) Ured Vijeća za nacionalnu sigurnost trajno usklađuje propisane mjere i standarde informacijske sigurnosti u Republici Hrvatskoj s međunarodnim standardima i preporukama informacijske sigurnosti te sudjeluje u nacionalnoj normizaciji područja informacijske sigurnosti.

Članak 16.

(1) Ured Vijeća za nacionalnu sigurnost koordinira i usklađuje rad tijela i pravnih osoba iz članaka 17., 20., 23. i 25. ovoga Zakona.

(2) Ured Vijeća za nacionalnu sigurnost surađuje s mjerodavnim institucijama stranih zemalja i organizacija u području informacijske sigurnosti te koordinira međunarodnu suradnju ostalih tijela i pravnih osoba iz stavka 1. ovoga članka.

Zavod za sigurnost informacijskih sustava

Članak 17.

(1) Zavod za sigurnost informacijskih sustava je središnje državno tijelo za tehnička područja sigurnosti informacijskih sustava u tijelima i pravnim osobama iz članka 1. stavka 2. ovoga Zakona.

(2) Tehnička područja sigurnosti informacijskih sustava su:

- standardi sigurnosti informacijskih sustava,
- sigurnosne akreditacije informacijskih sustava,
- upravljanje kriptomaterijalima koji se koriste u razmjeni klasificiranih podataka,
- koordinacija prevencije i odgovora na računalne ugroze sigurnosti informacijskih sustava.

Članak 18.

(1) Zavod za sigurnost informacijskih sustava pravilnikom će regulirati standarde tehničkih područja sigurnosti informacijskih sustava iz članka 17. stavka 2. ovoga Zakona.

(2) Zavod za sigurnost informacijskih sustava trajno usklađuje standarde tehničkih područja sigurnosti informacijskih sustava u Republici Hrvatskoj s međunarodnim standardima i preporukama te sudjeluje u nacionalnoj normizaciji područja sigurnosti informacijskih sustava.

Članak 19.

Zavod za sigurnost informacijskih sustava obavlja poslove sigurnosne akreditacije informacijskih sustava u suradnji s Uredom Vijeća za nacionalnu sigurnost.

NACIONALNI CERT

Članak 20.

- (1) CERT je nacionalno tijelo za prevenciju i zaštitu od računalnih ugroza sigurnosti javnih informacijskih sustava u Republici Hrvatskoj.
- (2) CERT je zasebna ustrojstvena jedinica koja se ustrojava u Hrvatskoj akademskoj i istraživačkoj mreži (u daljnjem tekstu: CARNet).
- (3) CERT usklađuje postupanja u slučaju sigurnosnih računalnih incidenata na javnim informacijskim sustavima nastalih u Republici Hrvatskoj, ili u drugim zemljama i organizacijama, kad su povezani s Republikom Hrvatskom.
- (4) CERT usklađuje rad tijela koja rade na prevenciji i zaštiti od računalnih ugroza sigurnosti javnih informacijskih sustava u Republici Hrvatskoj te određuje pravila i načine zajedničkog rada.

Članak 21.

CERT i Zavod za sigurnost informacijskih sustava surađuju na prevenciji i zaštiti od računalnih ugroza sigurnosti informacijskih sustava te sudjeluju u izradi preporuka i normi u Republici Hrvatskoj iz područja sigurnosti informacijskih sustava.

Članak 22.

Ravnatelj CARNet-a imenuje pomoćnika zaduženog za upravljanje CERT-om.

SAVJETNIK ZA INFORMACIJSKU SIGURNOST

- (1) Savjetnik za informacijsku sigurnost podnosi izvješće o rezultatima provedenog nadzora čelniku tijela ili pravne osobe te središnjem državnom tijelu za informacijsku sigurnost.
- (2) Središnje državno tijelo za informacijsku sigurnost, na temelju izvješća iz stavka 1. ovoga članka, ovlašteno je:
 - dati upute u svrhu otklanjanja utvrđenih nedostataka i nepravilnosti, koje su nadzirana tijela i pravne osobe dužne u određenom roku otkloniti,
 - provesti postupak preispitivanja daljnje valjanosti sigurnosne akreditacije informacijskog sustava,
 - pokrenuti postupak utvrđivanja odgovornosti,
 - poduzeti druge mjere i radnje za koje je posebnim propisima ovlašteno.
- (3) Čelnik tijela ili pravne osobe dužan je poduzeti mjere za otklanjanje nedostataka utvrđenih u provedbi nadzora.